



Executive Summary



Executive Summary



Threat Model Summary

Xibalba Interactive protects four key assets: proprietary game code, user payment data, private chat sessions, and core infrastructure. A misconfigured development server exposed the game's source repository, creating a clear path for intellectual property theft. The public stats site's guestbook is vulnerable to stored XSS, risking session hijacking of chat and payment services. Shared database credentials between environments, unprotected admin interfaces, and an open VPN endpoint further widen the attack surface. Adversaries from insiders to nation-state actors, could use supply-chain compromises, phishing, brute-force or remote-code exploits to steal code, drain user accounts, or eavesdrop on encrypted chats. Gaps in logging for process creation, file access, network traffic and authentication events mean these threats often go unseen.



Solution Roadmap Summary

Our roadmap combines early warning, real-time detection and human strengthening. We will deploy a decoy payment-library package to alert on supply-chain probes. We will centralize process-creation logs in the SIEM to catch suspicious installs, shells and privilege escalations as they happen. We will deliver quarterly, role-based phishing simulations and interactive workshops to teach staff how to spot social engineering. Together, these controls provide timely alerts on reconnaissance, precise detection of live attacks and improved staff vigilance, safeguarding Xibalba's intellectual property and customer data.





Threat Model for Xibalba Interactive



Threat Actors



Threat Actors

1. Insider Threats

- Insiders have direct access to critical systems and data chat logs, payment servers, source-code repos, databases and can siphon or tamper with them for financial gain or sabotage.
- They can exfiltrate encrypted chat snapshots for extortion, manipulate refund transactions, steal or clone proprietary game code, or dump customer databases using shared credentials.

- SCENARIO:

Malicious developer with VPN access to dev.xibalbainteractive.com copies the entire .git folder and database snapshots to a USB drive, exposing proprietary game source code and private chat archives.

Details: Because development and production share credentials, the insider simply pulls /var/www/dev/.git and /var/backups/payments.sql to an external device.

Attack Vectors: T1005 (Data from Local System), T1213 (Data from Information Repositories), T1078 (Valid Accounts)

2. Cybercriminals

- Criminals seek to monetize stolen payment data (card-not-present fraud), test skimmer tools, or harvest session tokens for resale.
- They use web-app vulnerabilities stored XSS, SQL injection, brute-force or phishing of admin consoles to inject skimmers, dump PCI-DSS databases, or crack merchant-portal credentials.

- SCENARIO:

Magecart-style skimmer injected via a stored XSS flaw on pay.xibalbagames.com/checkout captures credit-card data in real time as customers enter payment details.

Details: A script hidden in the comments widget exfiltrates card numbers to an attacker-controlled domain.

Attack Vectors: T1566.001 (Phishing: Spear Phishing Attachment for initial access), T1190 (Exploit Public-Facing Application), T1041 (Exfiltration Over C2 Channel)

3. Nation State Actors

- APTs target U.S. government employees playing Xibalba to gather intelligence or establish long-term footholds.
- They implant backdoors in proprietary code via supply-chain compromises, leak IPs or credentials, and maintain persistence in CI/CD pipelines.

- **SCENARIO:**

APT leverages a stolen CI token from dev.xibalbainteractive.com to push a malicious library into the NPM/Electron build pipeline, embedding a stealth backdoor in every release of the game client.”

- Details: By swapping in a trojanized xibalba-engine package, the actor achieves covert code execution on all player machines.

Attack Vectors: T1195.002 (Supply Chain Compromise: Software Supply Chain), T1553.002 (Subvert Trust Controls : Code Signing)



Attack Surface

Attack Surface

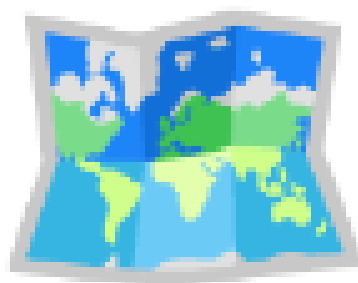
 Attack Surface.....1

Attack Surface	Asset(s)	ATT&CK TTPs	Likelihood	Impact
Browser Chat UI (stats.xibalbainteractive.com/js/chat.js)	Private Chat Feature	- T1059.007: Command and Scripting Interpreter JavaScript - T1190: Exploit Public-Facing Application	3 (Pos... ▾)	4 (Major) ▾
WebSocket Endpoint (wss://chat.xibalbainteractive.com)	Private Chat Feature	- T1557.003: Adversary-in-the-Middle – Web Proxy - T1040: Network Sniffing	2 (Unli... ▾)	5 (Cata... ▾)
Chat Send API (api.xibalbainteractive.com/chat/send)	Private Chat Feature	- T1078: Valid Accounts - T1190: Exploit Public-Facing Application	3 (Pos... ▾)	3 (Mod... ▾)
Chat Receive API (api.xibalbainteractive.com/chat/receive)	Private Chat Feature	- T1553.002: Subvert Trust Controls : Code Signing - T1005: Data from Local System	3 (Pos... ▾)	4 (Major) ▾
Chat Authentication Service (api.xibalbainteractive.com/auth)	Private Chat Feature	- T1550.003: Use Alternate Authentication Material - T1110.003: Credential Stuffing	4 (Like... ▾)	5 (Cata... ▾)
Chat Message Store (DB or Message Queue)	Private Chat Feature	- T1005: Data from Local System - T1210: Exploitation of Remote Services	2 (Unli... ▾)	4 (Major) ▾
Session Tokens (JWTs or Cookies) for chat sessions	Private Chat Feature	T1566.001: Phishing : Spearphishing Attachment	4 (Like... ▾)	4 (Major) ▾

Attack Surface	Asset(s)	ATT&CK TTPs	Likelihood	Impact
Payment Checkout UI (pay.xibalbagames.com/charge)	Payment Information	• T1195.002 : Supply Chain Compromise: Software Supply Chain)	3 (Pos... ▾)	5 (Cata... ▾)
Third-Party Gateway API calls	Payment Information	• T1041 : Exfiltration Over C2 Channel - T1557.002 : Adversary-in-the-Middle	2 (Unli... ▾)	4 (Major) ▾
Subscription Management UI (pay.xibalbagames.com/subscriptions)	Payment Information	• T1188.001 : Secure Native Messaging (CSRF prevention bypass via API misuse)	4 (Like... ▾)	3 (Mod... ▾)
Payment Processing API (pay.xibalbagames.com/api/process)	Payment Information	• T1190 : Exploit Public-Facing Application - T1078 : Valid Accounts	3 (Pos... ▾)	4 (Major) ▾
Payment Processing Database (PCI-DSS tables)	Payment Information	• T1531: Account Access Removal - T1190 : Exploit Public-Facing Application	3 (Pos... ▾)	5 (Cata... ▾)
Billing Admin Console UI (internet-accessible, no MFA)	Payment Information	• T1213: Data from Information Repositories	2 (Unli... ▾)	4 (Major) ▾
Exposed Git Repo (dev.xibalbainteractive.com/.git directory)	Proprietary Game Source Code	• T1213 : Data from Information Repositories	4 (Like... ▾)	5 (Cata... ▾)
CI/CD Server (Jenkins/GitLab pipelines, build logs)	Proprietary Game Source Code	• T1195.002 : Supply Chain Compromise: Software Supply Chain) - T1059.007 : Command and Scripting Interpreter: JavaScript	3 (Pos... ▾)	5 (Cata... ▾)
Stats Website UI (stats.xibalbainteractive.com)	Proprietary Game Source Code	• 1195.002 : Supply Chain Compromise: Software Supply Chain) - T1059.007 : Command and Scripting	3 (Pos... ▾)	3 (Mod... ▾)



Solution Roadmap



Solution Roadmap for Xibalba Interactive

Honey strategies



Honey strategy Solutions:

Honeypot Solutions:	1
Solution #1 NAME HERE.....	1
STAKEHOLDERS.....	2
Executives.....	2
IT Team.....	2
Legal.....	2
GOALS.....	2
ADD GOAL #1 NAME HERE.....	2
ADD GOAL #2 NAME HERE.....	2
ADD GOAL #3 NAME HERE.....	2
Solution #2 NAME HERE.....	2
STAKEHOLDERS.....	2
Executives.....	2
IT Team.....	2
Legal.....	2
GOALS.....	2
ADD GOAL #1 NAME HERE.....	2
ADD GOAL #2 NAME HERE.....	2
ADD GOAL #3 NAME HERE.....	2
Solution #3 NAME HERE.....	3
STAKEHOLDERS.....	3
Executives.....	3
IT Team.....	3
Legal.....	3
GOALS.....	3
ADD GOAL #1 NAME HERE.....	3
ADD GOAL #2 NAME HERE.....	3
ADD GOAL #3 NAME HERE.....	3
Solution #4 NAME HERE.....	3
STAKEHOLDERS.....	3
Executives.....	3
IT Team.....	3
Legal.....	3
GOALS.....	3
ADD GOAL #1 NAME HERE.....	3
ADD GOAL #2 NAME HERE.....	3

ADD GOAL #3 NAME HERE.....	3
Solution #5 NAME HERE.....	4
STAKEHOLDERS.....	4
Executives.....	4
IT Team.....	4
Legal.....	4
GOALS.....	4
ADD GOAL #1 NAME HERE.....	4
ADD GOAL #2 NAME HERE.....	4
ADD GOAL #3 NAME HERE.....	4

🍯 Honeypot Solution #1		
Honeyfile: "xibalba-pay-v1.2.3.tgz"	Difficulty: 1 (Easy) ▾	Priority: 2 (Medium) ▾
Drop a decoy payment-library package in your internal npm/Yarn repo; any download or extraction of this fake artifact alerts on supply-chain probing of payment components.		
Addresses attack vector(s):	T1195.002 : Supply Chain Compromise: Software Supply Chain	
Protects key asset(s):	Proprietary Game Source Code	
STAKEHOLDERS		
Executives	IT Team	Legal
Keeps payment data safe and protects our reputation by giving senior leaders confidence in our defenses.	A simple registry drop in that instantly alerts our team to any unauthorized package use.	Demonstrates to auditors that we meet supply chain monitoring requirements without additional work.
GOALS		
Name	Description	Deadline
Detect supply-chain reconnaissance	Any unauthorized download or extraction of xibalba-pay-v1.2.3.tgz triggers a high-priority SIEM alert and creates an incident ticket.	Within 24 hours

Verify SIEM ingestion	Confirm every honeyfile alert is fully ingested into SIEM, appears on the supply-chain dashboard, and auto-opens a ticket with correct metadata.	Within 1 week
Simulate reconnaissance	From a controlled staging host, perform a test download of the decoy package and validate end-to-end alerting, ticket creation, and on-call notification.	Within 2 weeks

🍯 Honeypot Solution #2		
Honeyservice: SSH on port 2222 (dev subnet)	Difficulty: 2 (Medium) ▾	Priority: 2 (Medium) ▾
Deploy a low-interaction SSH honeypot (e.g. Cowrie) on port 2222 in the development subnet. Any incoming SSH connection attempt triggers an immediate alert and is forwarded to the SIEM.		
Addresses attack vector(s):	- T1059.007 : Command & Scripting Interpreter (SSH)	
Protects key asset(s):	- Proprietary Game Source Code (on dev.xibalbainteractive.com)	
STAKEHOLDERS		
Executives	IT Team	Legal
Provides early warning of unauthorized SSH reconnaissance against our dev environment, reducing the risk of source-code theft and brand damage.	Any SSH attempt on port 2222 is 100 % malicious, no more noise. Alerts go straight to the team for immediate investigation.	Demonstrates continuous monitoring of internal access attempts, supporting compliance with SOC 2/ISO 27001 “infrastructure monitoring” controls.

GOALS		
Name	Description	Deadline
Detect SSH reconnaissance	Any connection to port 2222 triggers a high-priority SIEM alert, creating an incident ticket tagged "SSH honeypot."	Within 24 hours
Verify SIEM ingestion	Confirm every honeypot alert appears in the SIEM "Dev Recon" dashboard and auto-opens a ticket with correct metadata (source IP, timestamp).	Within 1 week
Simulate attacker probing	From a staging host, run an SSH brute-force test against port 2222; validate end-to-end alerting, ticket creation, and on-call notification workflows.	Within 2 weeks

👮 Honeypot Solution #3		
Honeyservice: fake upload endpoint (/upload?cmd=)	Difficulty: 2 (Medium) ▾	Priority: 2 (Medium) ▾
Stand up a decoy file-upload URL at /upload?cmd= on your public API server that never executes commands but logs every access to the cmd parameter. Any request containing ?cmd= triggers an immediate SIEM alert and ticket.		
Addresses attack vector(s):	- T1203 : Exploitation for Client Execution	
Protects key asset(s):	-Proprietary game code (api.xibalbainteractive.com)	

STAKEHOLDERS		
Executives	IT Team	Legal
Provides real-time detection of attempted RCE or file-include attacks, preventing service disruption and reputational harm.	Any request to /upload?cmd= is guaranteed malicious no false positives. Alerts surface direct attack attempts without sifting normal upload logs.	Demonstrates proactive web-application monitoring, satisfying PCI-DSS "complementary security control" requirements with documented alert records for auditors.
GOALS		
Name	Description	Deadline
Detect RCE probe attempts	Any HTTP request to /upload?cmd=<payload> triggers a high-priority SIEM alert labeled "RCE honeypot" and opens an incident ticket.	Within 24 hours
Verify SIEM workflow	Confirm honeypot alerts ingest properly into the SIEM "Web Recon" dashboard, carry correct metadata (source IP, user agent, timestamp), and auto-create tickets.	Within 1 week
Simulate exploit reconnaissance	From a controlled test host, send crafted requests to /upload?cmd=ls (and other payloads), then validate end-to-end alerting, ticket creation, and on-call notification.	Within 2 weeks

Honeypot Solution #4

Honeytoken URL: /xibalba-secure-portal/login?token=HNY	Difficulty: 1 (Easy) ▾	Priority: 2 (Medium) ▾
Publish a fake “restricted” login link (/xibalba-secure-portal/login?token=HNY) in internal documentation and wikis. Any HTTP GET to this URL triggers an immediate SIEM alert and incident ticket.		
Addresses attack vector(s):	- T1566.003 : Phishing – Spearphishing Link	
Protects key asset(s):	- Payment Information(pay.xibalbagames.com/admin)	
STAKEHOLDERS		
Executives	IT Team	Legal
Provides early warning of targeted phishing campaigns against our payment portal, safeguarding revenue and reputation.	A guaranteed-phishing click, no false positives. Alerts let you immediately investigate compromised mailings or insider leaks.	Demonstrates that Xibalba actively tests and detects phishing, fulfilling PCI-DSS and GDPR requirements for user awareness and incident detection controls.
GOALS		
Name	Description	Deadline
Detect phishing link clicks	Any GET to /xibalba-secure-portal/login?token=HNY fires a high-priority SIEM alert and opens an incident ticket.	Within 24 hours
Verify alert ingestion	Confirm every honeypot alert appears in the SIEM “Phishing Watch” dashboard with correct	Within 1 week

	metadata (user, IP, timestamp) and auto-tickets.	
Simulate employee phishing	Send a controlled “phishing” email to a pilot group embedding the honeypot URL; validate end-to-end detection and response workflows.	Within 2 weeks

Honeypot Solution #5

Honeyfile: .env.backup	Difficulty: 1 (Easy) ▾	Priority: 2 (Medium) ▾
Place a decoy backup of your environment file (.env.backup) in the configuration repository. Any read or copy of that file triggers an immediate SIEM alert and opens an incident ticket.		
Addresses attack vector(s):	– T1602 : Data from Configuration Repository	
Protects key asset(s):	– Configuration secrets (API keys, database credentials)	
STAKEHOLDERS		
Executives	IT Team	Legal
Ensures we catch any attempt to harvest our configuration credentials before damage occurs, protecting customer data and Xibalba’s reputation.	A simple file-read trigger, no false positives. You’ll get instant alerts whenever anyone accesses the decoy .env.backup, so you can investigate immediately.	Shows auditors we monitor access to sensitive configuration data, meeting PCI-DSS and GDPR logging requirements for credential and key-management controls.

GOALS		
Name	Description	Deadline
Detect config harvesting	Any read or copy of .env.backup fires a high-priority SIEM alert and opens an incident ticket.	Within 24 hours
Verify alert pipeline	Confirm each honeypot alert is ingested into the "Configuration Watch" SIEM dashboard with correct host and user tags.	Within 1 week
Simulate exfiltration probe	From a staging host, perform a scripted cp .env.backup /tmp/test and validate end-to-end alerting and on-call paging.	Within 2 weeks



Data sources



Data Sources:

 Data Sources:	1
Solution #1 NAME HERE.....	1
STAKEHOLDERS.....	2
Executives.....	2
IT Team.....	2
Legal.....	2
GOALS.....	2
ADD GOAL #1 NAME HERE.....	2
ADD GOAL #2 NAME HERE.....	2
ADD GOAL #3 NAME HERE.....	2
Solution #2 NAME HERE.....	2
STAKEHOLDERS.....	2
Executives.....	2
IT Team.....	2
Legal.....	2
GOALS.....	2
ADD GOAL #1 NAME HERE.....	2
ADD GOAL #2 NAME HERE.....	2
ADD GOAL #3 NAME HERE.....	2
Solution #3 NAME HERE.....	3
STAKEHOLDERS.....	3
Executives.....	3
IT Team.....	3
Legal.....	3
GOALS.....	3
ADD GOAL #1 NAME HERE.....	3
ADD GOAL #2 NAME HERE.....	3
ADD GOAL #3 NAME HERE.....	3
Solution #4 NAME HERE.....	3
STAKEHOLDERS.....	3
Executives.....	3
IT Team.....	3
Legal.....	3
GOALS.....	3
ADD GOAL #1 NAME HERE.....	3
ADD GOAL #2 NAME HERE.....	3

ADD GOAL #3 NAME HERE.....	3
Solution #5 NAME HERE.....	4
STAKEHOLDERS.....	4
Executives.....	4
IT Team.....	4
Legal.....	4
GOALS.....	4
ADD GOAL #1 NAME HERE.....	4
ADD GOAL #2 NAME HERE.....	4
ADD GOAL #3 NAME HERE.....	4

 Data Source Solution #1		
DS0009: Process : Process Creation	Difficulty: 2 (Medium) ▾	Priority: 3 (High) ▾
ADD SOLUTION SUMMARY HERE		
Addresses attack vector(s):	- T1195.002: Supply Chain Compromise: Software Supply Chain - T1190: Exploit Public-Facing Application - T1203 : Exploitation for Client Execution - T1021 : Remote Services - T1548.003 : Setuid and Setgid (Abuse Elevation Control Mechanism) - T1059.007: Command and Scripting Interpreter JavaScript - T1553.002: Subvert Trust Controls – Code Signing - T1059.007 : Command and Scripting Interpreter: JavaScript - T1195.002 : Supply Chain Compromise: Software Supply Chain	
STAKEHOLDERS		
Executives	IT Team	Legal
“By alerting on any unapproved installs or shells, we stop zero-day backdoors before they can steal our source code or customer data,protecting revenue and Xibalba’s reputation.”	“We leverage existing host logs no new agents. A handful of SIEM rules surfaces every malicious subprocess and privilege-escalation in real time, cutting alert noise.”	“Centralizing these events meets PCI-DSS 10.2’s requirement to log all system/process actions. We’ll have a tamper-proof trail for audits and demonstrate continuous monitoring.”

GOALS		
Name	Description	Deadline
Detect unauthorized installs	Simulate npm install xibalba-skimmer on a staging build host. SIEM must fire a "new process" alert and open a ticket within 30 minutes.	Within 24 hours
Capture shell spawn attempts	As a non-privileged user, run bash -i or ssh dev.xibalba. SIEM should generate a "shell spawn" incident within 1 hour.	Within 3 days
Flag privilege abuse	Execute sudo -u root id as a developer account. SIEM must log and alert on unauthorized sudo/setuid use, including user and command details, within 2 hours.	Within 1 week

 Data Source Solution #2		
DS0022: File : File Access	Difficulty: 2 (Medium) ▾	Priority: 3 (High) ▾
Monitor file reads of code-signing certificates or signing tools.		
Addresses attack vector(s):	- T1553.002: Subvert Trust Controls – Code Signing - T1005: Data from Local System - T1552.003: Steal or Forge Certificates - T1081: Credentials in Files - T1195.002 : Supply Chain Compromise: Software Supply Chain - T1213: Data from Information Repositories - T1005: Data from Local System - T1552.001 : Credentials in Files: Private Keys and Certificates - T1602: Data from Configuration Repository	

STAKEHOLDERS		
Executives	IT Team	Legal
We'll see any mass download of our code or customer data before it leaves the network, safeguarding Xibalba's IP and subscriber trust.	A small set of file-access rules generates high-fidelity alerts—no more sifting through millions of file-open logs to find data theft.	This satisfies PCI-DSS 10.2.5 & 3.5 by proving we log and alert on all access to cardholder data and key materials with a full audit trail
GOALS		
Name	Description	Deadline
Catch bulk repo reads	From a staging host, run <code>cp -r /var/www/dev/.git /tmp/exfil</code> ; SIEM must alert on <code>.git/objects</code> file reads within 15 minutes.	Within 24 hours
Flag secret file access	As a non-privileged user, attempt to <code>cat /etc/vault/keys/master.pem</code> ; SIEM should fire an alert with process, user and path details in under 30 minutes.	Within 3 days
Monitor config file harvesting	Trigger a scripted download of <code>config.json</code> and <code>.env</code> ; SIEM must detect and ticket both events within 1 hour.	Within 1 week

 Data Source Solution #3		
DS0028: Logon Session : Creation	Difficulty: 1 (Easy) ▾	Priority: 2 (Medium) ▾
Correlate successful logons from new IPs or devices.		

Addresses attack vector(s):	- T1078: Valid Accounts - T1550.003: Use Alternate Authentication Material - T1110.003: Credential Stuffing - T1531: Account Access Removal	
STAKEHOLDERS		
Executives	IT Team	Legal
By flagging odd login patterns before damage occurs, we reduce fraud losses and preserve Xibalba’s brand and subscriber confidence	One rule in the SIEM lets us instantly spot compromised credentials, no manual log hunts saving hours each week and accelerating our response.	Centralized logging and alerting on all authentication events fulfills PCI-DSS 10.2 and GDPR requirements for tracking access to sensitive data, ensuring audit readiness
GOALS		
Name	Description	Deadline
Detect credential stuffing	Simulate 50 rapid failed logins against chat.xibalbagames.com; SIEM must alert on burst-failure pattern within 10 minutes.	Within 24 hours
Flag anomalous admin access	From a new office IP, log in to pay.xibalbagames.com/admin; SIEM should trigger a “new source” alert with user and IP detail in under 30 minutes.	Within 3 days
Monitor after-hours logins	Schedule a login to the billing console at 2 AM; SIEM must send an “outside hours” alert within 15 minutes and open a security ticket.	Within 1 week



Data Source Solution #4

DS0029: Network Traffic : Content

Difficulty: 2 (Medium) ▾

Priority: 3 (High) ▾

Detect anomalous network traffic to remote-service ports.

Addresses attack vector(s):

- T1190: Exploit Public-Facing Application
- T1040: Network Sniffing
- T1210: Exploitation of Remote Services
- T1041 : Exfiltration Over C2 Channel
- T1190 : Exploit Public-Facing Application
- T1537 : Transfer Data to Cloud Account
- T1021 : Remote Services
- T1189 : Drive-by Compromise (SSRF)
- T1602: Data from Configuration Repository

STAKEHOLDERS

Executives

IT Team

Legal

We'll block and detect injection attempts in real time, preventing costly data breaches of player chats or payment data

We get precise, contextual alerts on the exact malicious payload, and line numbers, so we can triage and patch within minutes, not hours.

Deep-packet inspection logs satisfy PCI-DSS 11.4 and GDPR Art. 32 by proving we inspect and record content-level traffic for malicious activity

GOALS

Name

Description

Deadline

Stop SQLi probes

Send a GET /api/process?query=' OR '1'='1'; SIEM must alert on SQLi signature within 10 minutes with full payload context.

Within 24 hours

Catch skimmer scripts

Deploy a test payload mimicking a Magecart skimmer JS on checkout page; SIEM should fire on known skimmer signature within 1 hour.

Within 3 days

Detect malformed JSON	Send a deliberately malformed JSON body to both API and chat endpoints; SIEM must flag the parsing error pattern and open a ticket within 2 hours.	Within 1 week
------------------------------	--	---------------

 Data Source Solution #5		
DS0038: Domain Name : DNS Query	Difficulty: 1 (Easy) ▾	Priority: 2 (Medium) ▾
Forward all DNS query logs from your recursive resolvers and firewall to the SIEM. Enrich queries with threat-intel feeds and alert on: 1. Lookups to known phishing or typosquatting domains 2. Queries to newly registered domains (<7 days old) from dev or finance hosts 3. Repeated failed lookups signaling C2 fallback behavior		
Addresses attack vector(s):	- T1566.003 Phishing : Spearphishing Link - T1557.003 Adversary-in-the-Middle : Web Proxy - T1537 Transfer Data to Cloud Account	
STAKEHOLDERS		
Executives	IT Team	Legal
We'll catch phishing campaigns and C2 domain lookups early, protecting user payments and developer credentials before any compromise	"Automated TI-enrichment means we only receive alerts for truly suspicious domains no manual block-list updates so we can respond in minutes	Maintains PCI-DSS 10.6 and GDPR audit trails by logging all DNS activity with enrichment and alert history, demonstrating proactive network monitoring.

GOALS		
Name	Description	Deadline
Flag phishing domains	Query a known phishing domain (from ThreatFeed); SIEM must alert on domain reputation match within 5 minutes.	Within 24 hours
Detect typosquat lookups	Generate DNS lookups for pay.xibalbagames.com and stats.xibalbainteractiv.com; SIEM must flag lookups to newly registered variants.	Within 3 days
Spot C2 fallback patterns	Simulate 10 failed DNS queries to non-existent subdomains of hny.xibalba; SIEM should detect repeated NXDOMAIN events and open a ticket.	Within 1 week



Mitigations



Preventive Mitigations:

 Preventive Mitigations:	1
Solution #1 NAME HERE.....	1
STAKEHOLDERS.....	2
Executives.....	2
IT Team.....	2
Legal.....	2
GOALS.....	2
ADD GOAL #1 NAME HERE.....	2
ADD GOAL #2 NAME HERE.....	2
ADD GOAL #3 NAME HERE.....	2
Solution #2 NAME HERE.....	2
STAKEHOLDERS.....	2
Executives.....	2
IT Team.....	2
Legal.....	2
GOALS.....	2
ADD GOAL #1 NAME HERE.....	2
ADD GOAL #2 NAME HERE.....	2
ADD GOAL #3 NAME HERE.....	2
Solution #3 NAME HERE.....	3
STAKEHOLDERS.....	3
Executives.....	3
IT Team.....	3
Legal.....	3
GOALS.....	3
ADD GOAL #1 NAME HERE.....	3
ADD GOAL #2 NAME HERE.....	3
ADD GOAL #3 NAME HERE.....	3



Preventive Solution #1

M1017: User Training

Difficulty: 2 (Medium) ▾

Priority: 2 (Medium) ▾

Regular security training and phishing awareness for users to identify and report attacks.

Addresses attack vector(s):

- T1566.001 : Phishing: Spearphishing Attachment,
- T1566.003: Phishing – Spearphishing Link

STAKEHOLDERS

Executives

IT Team

Legal

Regular, targeted simulations will reduce successful phishing clicks and demonstrate to our board that we manage human risk proactively

Hands-on exercises tailored to our systems mean our team will recognize and report real phishing attempts faster, reducing false negatives and incident workload.

Documented training and simulation results satisfy PCI-DSS 12.6 and GDPR requirements for ongoing security awareness, simplifying audit preparation.

GOALS

Name

Description

Deadline

Reduce click-through rate

Achieve a simulated-phish click rate below 10% among finance and dev staff after two quarters of training.

6 months

Complete participation

Ensure 100% of staff complete the training modules and simulations, with records logged in the LMS.

3 months

Measure reporting speed

Increase average time to report simulated phish from 48 hours to under 4 hours by end of next quarter.

4 months



Preventive Solution #2

M1018: User Account Management

Difficulty: 2 (Medium) ▾

Priority: 3 (High) ▾

Restrict access to critical repositories

Addresses attack vector(s):

- T1213: Data from Information Repositories,
- T1078 : Valid Accounts,
- T1552.004: Compromise Hardware Security Modules

STAKEHOLDERS

Executives

IT Team

Legal

Automating access controls reduces risk of orphaned accounts and demonstrates strong governance to investors and auditors.

Centralized IAM simplifies user onboarding/offboarding, reduces help-desk tickets, and ensures immediate revocation of access when needed.

Comprehensive audit trails and recertification reports satisfy PCI-DSS 7.1.1 and GDPR Art. 32, reducing compliance burden.

GOALS

Name

Description

Deadline

Implement RBAC

Configure role-based access for all developer and finance systems, eliminating any shared or generic accounts.

2 months

Automate deprovisioning

Integrate HR system to trigger automated deprovisioning within one hour of employee departure.

1 month

Access recertification	Conduct the first full recertification of all privileged accounts, confirming no over-privileged access.	3 months
-------------------------------	--	----------

 Preventive Solution #3		
M1026: Privileged Account Management	Difficulty: 3 (Hard) ▾	Priority: 3 (High) ▾
Control and strictly monitor usage of privileged accounts to prevent unauthorized privilege use.		
Addresses attack vector(s):	- T1548.003 : Setuid and Setgid (Abuse Elevation Control Mechanism), - T1531: Account Access Removal, - T1078 : Valid Accounts	
STAKEHOLDERS		
Executives	IT Team	Legal
PAM ensures no standing high-privilege credentials exist, reducing our attack surface and showing the board we follow best practices.	Ephemeral credentials with MFA and approval workflows mean you never manage static keys, and every action is recorded for rapid forensics.	Session recordings and approval logs meet PCI-DSS 3.5 and NIST requirements for privileged access, providing auditors with clear evidence of control.
GOALS		
Name	Description	Deadline
Deploy PAM gateway	Install and configure PAM for SSH and database console access in dev and prod environments.	2 months

Enforce just-in-time elevation	Require MFA and explicit approval for all privilege elevation requests, with logging enabled.	1 month
Validate session recordings	Conduct a review of recorded privileged sessions and confirm audit logs are tamper-proof and accessible.	3 months